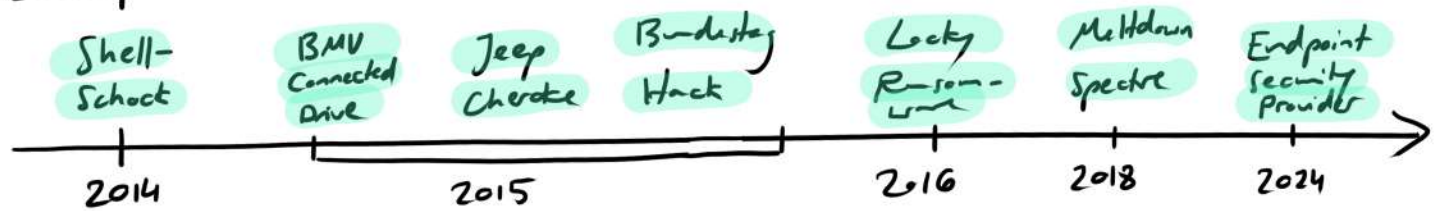


Chapter 1



Shell-Schock: Bash - Vulnerability (2014)

→ execution of malicious code via **Code Injection**

BMW Connected Drive (2015)

→ **weak security concept** allowed unlocking of door

Weak points: same **symmetrical key** in all vehicles

no transport encryption on some services

integrity of ConnectedDrive config not protected

error messages revealed critical information (VIN)

used **insecure DES** encrypt. method for SMS

no protection against **replay attacks**

Jeep Cherokee (2015)

→ **vulnerability in infotainment sys** allowed control-taking of jeep
works over internet

Bundestag Hack (2015)

→ **Drive-by-Download** via email attachment, theft of credentials for domain admin roles
(automatic download and installation)

→ **Pass-the-Hash**: circumvent clear text pwd by directly inputting hash

↳ lateral movement (get access to acc on same clearance level)

privilege escalation (gain higher lvl permission, e.g. admin roles)

↳ mitigations: restrict/protect high privileged domain accs/local acc with admin
restrict inbound traffic with firewalls

Locky Ransomware (2016)

→ macro in email attach saves file that reloads malware
encrypts all files and deletes all shadow copies

Process

Browser

Meltdown/Spectre (2018)

↳ **access to memory** (cache) of foreign processes provided by exception

↳ **extract info** from address space of web browser

Endpoint Security Provider (2024)

→ **update failure** leads to Windows sys crash

Computer viruses

Computer Virus



- only works as **program part** within **host program**
- is executed with host program

Worm



- independent program : **creates copies of self** and **executes them**

Trojan Horse



- **standalone program** contain undocumented routine that performs unexpected, mostly destructive **additional function**
- popular for collecting passwords

Ransomware



- **encrypts data** and **demand** **ransom** for decrypt

Spyware



- **monitors user activity** and collects sensitive data

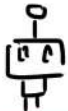
Adware



- **aggressive advertising software**, collect browser data or compromise security by creating **open door** for malicious programs

Malware

Bots



- **runs automated tasks** over internet network of hijacked computers → **botnet**

Keylogger



- records **user's keystrokes** and **clipboard** and **sends** to attacker

Rootkit



- give attacker **admin rights** and **remote access** while **hiding presence**

Exploit



- takes **advantage of vulnerabilities** to attack software and systems

Denial of Service Attacks

- **disable, shutdown or disrupt** network, website or service
- ↳ **overload** sys, **provoke errors**, **call time-consuming actions**
- **Distributed Denial of Service (DDoS)** via **coordinated attack** from multiple (hacked) machines

Security and Safety

Security (information security)

- ↳ no unauthorized information modification or extraction
- ↳ minimize vulnerability of assets and resources

Safety

- ↳ sys works and avoid accidents
- ↳ protection against accidental events / malfunctions that affect correct functionality and operational safety

Core values and objectives of information security

CIA Vertraulichkeit, Integrität, Verfügbarkeit

Confidentiality → no unauthorized access to data, messages and functions

Integrity → no unauthorized manipulation of data and functions

Availability → data/functions always available when needed

Nicht Abstreitbarkeit

Non Repudiation → every action performed verifiable exactly as it happened

Authenticity → auth of data, accountability of messages

Information Security Management System ISMS

Why → set strategic sec goals

What → find sec-requirements
↳ crit app and data
→ risk assessment

How → distribute tasks and responsibilities
define policies and guidelines
implement sec processes, measures and controls
↳ awareness via training (humans major weak point)

Proof → regular audits

← redefine

Vulnerability → security-relevant error of an IT sys

Threat → exploitation of ≥ 1 vuln. to compromise ≥ 1 protection objectives

Risk R → probability of occurrence of damage event, potential extent of damage

3